Plan semanal

Ciberseguridad Aplicada — 10 semanas

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Cada práctica se entrega en GitHub, dentro de la carpeta semana_NN, antes del corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige. El docente revisa esa entrega al finalizar la semana.

Semana 1 — Panorama de la ciberseguridad y superficie de ataque

Fase 1 — Fundamentos, criptografía y marco legal
Objetivo. Distinguir activos, amenazas y vulnerabilidades, y describir el ciclo de vida de un ataque con marcos reconocidos.
Contenidos

- Tríada CIA más autenticidad, integridad y no repudio.
- Actores: oportunista, crimen organizado, insider y APT.
- Superficie de ataque, vector y cadena de explotación.
- Cyber Kill Chain y MITRE ATT&CK como vocabulario común.
- Roles rojo, azul y púrpura; modelos de amenaza STRIDE.
- Riesgo como función de probabilidad e impacto.

Herramientas: Docker, nmap sobre localhost, Navegador.
Práctica. *Inventario de superficie de ataque del laboratorio*. El laboratorio tiene tres contenedores. Cada grupo inventaría puertos, servicios y versiones de su objetivo asignado, y propone tres vectores plausibles por servicio expuesto.
Entregable: Tabla de activos y servicios, modelo STRIDE y conclusión priorizada de tres vectores.
Instrumento de evaluación: formativa.

Semana 2 — Criptografía aplicada y gestión de secretos

Fase 1 — Fundamentos, criptografía y marco legal
Objetivo. Aplicar cifrado simétrico y asimétrico, funciones hash y derivación de claves, y diagnosticar una configuración TLS insegura.
Contenidos

- Cifrado simétrico AES en modos GCM y CBC, y por qué GCM aporta integridad.
- Cifrado asimétrico RSA y curvas elípticas; intercambio de claves.
- Hash criptográfico, HMAC y funciones de derivación PBKDF2 y Argon2.
- TLS 1.2 y 1.3, cadena de certificados y errores de validación.
- Gestión de secretos y detección de claves en repositorios.

Herramientas: openssl, sha256sum, Python hashlib.
Práctica. *Caja de herramientas criptográficas*. Cada grupo cifra y descifra un archivo, firma y verifica un mensaje, inspecciona un certificado real y mide el coste de derivar una clave con distinto número de iteraciones.

Entregable: Registro de comandos, salidas y una tabla que asigne cada primitiva a la propiedad que garantiza.
Instrumento de evaluación: formativa.

Semana 3 — Marco legal, ético y normativo

Fase 1 — Fundamentos, criptografía y marco legal
Objetivo. Identificar las obligaciones legales y normativas antes de auditar, y redactar un alcance autorizado con reglas de enfrentamiento.
Contenidos

- Ley Especial contra los Delitos Informáticos y tipos penales aplicables.
- Autorización escrita, alcance, ventana de pruebas y reglas de enfrentamiento.
- ISO IEC 27001, NIST CSF 2.0, ENS y GDPR como marcos de referencia.
- OWASP ASVS y WSTG como estándares de verificación técnica.
- Cadena de custodia, integridad de la evidencia y confidencialidad.
- Código de ética del curso y consecuencias del uso indebido.

Herramientas: Plantilla de autorización, Normativa en PDF.
Práctica. *Carta de autorización y análisis de caso*. Cada grupo redacta la autorización de la auditoría de su objetivo del laboratorio y analiza un incidente ficticio, identificando qué normas se violaron y qué evidencia sería admisible.
Entregable: Autorización firmada, análisis del caso y código de ética firmado por cada estudiante.
Instrumento de evaluación: control fase 1.

Semana 4 — Reconocimiento, OSINT y escaneo de puertos

Fase 2 — Ofensiva controlada
Objetivo. extgreater Obtener información de un dominio autorizado sin generar tráfico intrusivo, descubrir hosts y escanear puertos, distinguiendo técnicas y su ruido.
Contenidos

- Registros DNS A, AAAA, MX, NS, TXT y SOA.
- WHOIS y RDAP; datos del registrante y fechas de vigencia.
- Enumeración de subdominios y motores de búsqueda especializados.
- Google dorks y su uso legítimo en un alcance autorizado.
- OPSEC del auditor y protección de la identidad durante la recolección.
- Descubrimiento con ARP, ICMP y sondeo TCP a puertos comunes.
- Escaneo connect, SYN semiabierto y UDP con ICMP port unreachable.
- Estados de puerto, banner grabbing y fingerprinting.
- Sigilo, ruido y detección; límites éticos del escaneo.

Herramientas: nmap como referencia, Scapy, Python dnspython, python-whois, dig, socket.
Práctica. *Huella digital + escáner propio contra el laboratorio*. extgreater Cada grupo construye un script que genere la huella digital (DNS/WHOIS) y un escáner propio, ejecutándolo contra los contenedores del laboratorio y comparando con nmap.

Entregable: Script integrado (huella digital + escáner), salida JSON, huella digital razonada, tabla comparativa con nmap y análisis de falsos positivos.
Instrumento de evaluación: formativa.

Semana 5 — Vulnerabilidades web según OWASP Top 10

Fase 2 — Ofensiva controlada
Objetivo. Explotar de forma controlada inyección SQL, XSS y LFI, y explicar la causa raíz y el control que lo evita.
Contenidos

- OWASP Top 10 2021 y categorías con mayor impacto.
- Control de acceso roto y exposición de datos sensibles.
- Inyección SQL, XSS reflejado y almacenado, LFI y RFI.
- Configuración insegura y componentes desactualizados.
- Evidencia reproducible, capturas y causa raíz en el código.

Herramientas: DVWA, Juice Shop, Navegador con herramientas de desarrollo.
Práctica. *Explotación guiada y evidencia*. Cada grupo explota tres vulnerabilidades en DVWA y resuelve tres retos de Juice Shop, documentando payload, evidencia, causa raíz y mitigación.
Entregable: Informe técnico con payloads, evidencia anonimizada, causa raíz y mitigación por hallazgo.
Instrumento de evaluación: control fase 2.

Semana 6 — Hardening, firewall y detección

Fase 3 — Defensa y hardening
Objetivo. extgreater Aplicar endurecimiento de sistemas, configurar filtrado por defecto y comprobar la detección con Suricata.
Contenidos

- Mínimo privilegio, usuarios del sistema y política de sudo.
- Permisos SUID, SGID y archivos con escritura global.
- SSH con claves, desactivación de contraseña y fail2ban.
- Parcheo, servicios innecesarios y CIS Benchmarks.
- Endurecimiento de systemd y perfiles de AppArmor.
- Línea base medible y verificación posterior.
- Política por defecto, nftables/ufw y segmentación.
- IDS/IPS con Suricata, firmas y lectura de alertas.
- TLS en tránsito y verificación de certificados.
- Comprobar que la detección ve el ataque frenado por la política.

Herramientas: systemd-analyze security, fail2ban, openssh, Suricata, ubuntu 24.04, nftables, ufw.
Práctica. *Línea base, hardening, firewall y detección*. extgreater Cada grupo endurece el contenedor, aplica política de filtrado, repite el escaneo y analiza las alertas de Suricata.
Entregable: Auditor propio, hardening antes/después, reglas de firewall, comparativa de alcance y alertas de Suricata clasificadas.

Instrumento de evaluación: formativa.

Semana 7 — Desarrollo seguro y cadena de suministro

Fase 3 — Defensa y hardening
Objetivo. Corregir vulnerabilidades en código y demostrar la mitigación repitiendo el mismo payload, con controles automatizados en la cadena de suministro.
Contenidos

- Validación de entrada y salida, parametrización de consultas.
- Codificación de salida, CSP y cabeceras de seguridad.
- Gestión de dependencias, SBOM y pip-audit.
- Análisis estático con bandit y escaneo de secretos.
- Revisión de código y criterios de aceptación de seguridad.

Herramientas: bandit, pip-audit, DVWA editado.
Práctica. *Parchear y demostrar la mitigación*. Cada grupo corrige tres vulnerabilidades de la semana 5 en su copia del laboratorio y demuestra que el payload original ya no funciona.
Entregable: Parches, evidencia antes y después con el mismo payload, y salida de los tres controles.
Instrumento de evaluación: control fase 3.

Semana 8 — Forense digital: adquisición, artefactos y línea de tiempo

Fase 4 — Forense y respuesta a incidentes
Objetivo. extgreater Adquirir evidencia forense con cadena de custodia, reconstruir el incidente a partir de artefactos y extraer IoCs.
Contenidos

- Principio de intercambio de Locard y orden de volatilidad.
- Adquisición lógica y física; diferencia y cuándo usar cada una.
- Herramientas dd y dcfldd, y montaje en solo lectura.
- Hash antes y después, y verificación de integridad.
- Formulario de cadena de custodia y registro de transferencias.
- Registros de autenticación, journald y syslog.
- Historial de shell, cron, timers y servicios añadidos.
- Usuarios, grupos, SUID y paquetes instalados fuera de política.
- Persistencia típica en Linux y su rastro.
- Construcción de línea de tiempo e indicadores de compromiso.

Herramientas: dcfldd, grep y awk, mount en solo lectura, sha256sum, journalctl.
Práctica. *Imagen forense, reconstrucción y línea de tiempo*. extgreater Cada grupo adquiere imagen forense, reconstruye la secuencia del compromiso simulado y construye línea de tiempo con IoCs.
Entregable: Imagen forense con hashes, formulario de custodia, línea de tiempo, relato del incidente y tabla de IoCs.
Instrumento de evaluación: formativa.

Semana 9 — Respuesta a incidentes y triage estático de malware

Fase 4 — Forense y respuesta a incidentes
Objetivo. Aplicar un playbook de respuesta y realizar triage estático de una muestra inerte sin ejecutarla.
Contenidos

- NIST SP 800-61: preparación, detección, contención, erradicación y recuperación.
- Playbooks, roles, comunicación y registro de decisiones.
- Triage estático con hashes, strings, cabeceras y reglas YARA.
- Límites legales y técnicos del análisis dinámico.
- Informe post mortem y acciones de mejora.

Herramientas: file y strings, YARA, sha256sum.
Práctica. *Playbook y triage estático*. Cada grupo escribe el playbook del incidente reconstruido en la semana 8 y realiza triage estático de una muestra inerte entregada por el docente.
Entregable: Playbook de una página, informe de triage y regla YARA probada, más post mortem.
Instrumento de evaluación: formativa.

Semana 10 — Evaluación final práctica de alcance cerrado

Fase 5 — Cierre
Objetivo. Ejecutar una auditoría completa de alcance cerrado sobre el laboratorio y comunicar los resultados en dos registros, técnico y ejecutivo.
Contenidos

- Repaso integrado de las cuatro fases.
- Diferencia entre informe técnico y resumen ejecutivo.
- Priorización de hallazgos por riesgo y esfuerzo de remediación.
- Defensa oral de decisiones y limitaciones del alcance.

Herramientas: Todo el laboratorio.
Práctica. *Auditoría de alcance cerrado*. Evaluación individual de cuatro horas sobre un alcance definido por el docente. Se entregan informe técnico, resumen ejecutivo y una defensa oral de diez minutos.
Entregable: Informe técnico, resumen ejecutivo, evidencia preservada y defensa oral.
Instrumento de evaluación: final.